TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI TP. HỒ CHÍ MINH KHOA CÔNG NGHỆ THÔNG TIN
BÁO CÁO BÀI TẬP LỚN MÔN AN TOÀN THÔNG TIN

KIỂM THỬ PHÂN QUYỀN ĐỐI TƯỢNG VÀ GIỚI HẠN LẠM DỤNG API

Nhóm: [Mã nhóm]

Sinh viên thực hiện: [Họ tên - MSSV của 3 thành viên]

Giảng viên hướng dẫn: [Họ tên]

Ngành / chuyên ngành: [Điền theo hồ sơ lớp]

TP. Hồ Chí Minh, tháng 11 năm 2026

LỜI CẢM ƠN

Nhóm trân trọng cảm ơn giảng viên học phần An toàn thông tin đã cung cấp định hướng nghiên cứu và yêu cầu thực nghiệm. Báo cáo trình bày kết quả kiểm thử trên môi trường giả lập do nhóm xây dựng, phục vụ mục đích học tập và đánh giá cơ chế bảo vệ API.

Các nhận định trong báo cáo dựa trên mã nguồn, ma trận quyền và dữ liệu kiểm thử được lưu kèm hồ sơ. Nhóm chịu trách nhiệm về tính chính xác của số liệu, đồng thời trình bày rõ các giới hạn của môi trường thử nghiệm.

TÓM TẮT

Đề tài nghiên cứu lỗi phân quyền ở cấp đối tượng và chức năng cùng các hình thức lạm dụng API. Nhóm xây dựng MiniBank-Lab, một API giả lập có hai chế độ: trước và sau khi bổ sung kiểm soát. Tác nhân, tài khoản, token và giao dịch đều là dữ liệu tổng hợp. Ma trận 24 quy tắc xác định quan hệ giữa chủ thể, hành động, tài nguyên và điều kiện nghiệp vụ trước khi xây dựng ca kiểm thử.

Bộ kiểm thử Python triển khai 26 tình huống, bao gồm BOLA, BFLA, mass assignment, JWT, rate limit, idempotency, giới hạn cộng dồn và ghi log. Trong lần chạy dùng cho báo cáo, bản đã sửa đạt 26/26 điều kiện kiểm tra. Độ trễ p95 đo qua ASGI cùng tiến trình lần lượt là 2,781 ms và 2,970 ms; phép đo chỉ có ý nghĩa tham khảo trong lab. OPA được xác minh riêng bằng Docker Compose với quyết định cho phép và từ chối.

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Diễn giải
API	Application Programming Interface
BOLA	Broken Object Level Authorization
BFLA	Broken Function Level Authorization
JWT	JSON Web Token
OPA	Open Policy Agent
MFA	Multi-Factor Authentication
ASGI	Asynchronous Server Gateway Interface
CI	Continuous Integration

Từ viết tắt	Diễn giải
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege

MỤC LỤC

Trong Microsoft Word, chọn toàn bộ tài liệu và nhấn F9 để cập nhật mục lục và số trang.

LỜI CẢM ƠN

TÓM TẮT

DANH MỤC TỪ VIẾT TẮT

MỤC LỤC

MỞ ĐẦU

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT

1.4. CÁC KIỂU LỖI API TRỌNG YẾU

1.5. NGUYÊN TẮC KIỂM SOÁT

CHƯƠNG 2. THIẾT KẾ LAB

2.4. MA TRẬN PHÂN QUYỀN

2.5. MÔ HÌNH ĐE DỌA

2.6. ĐẶC TẢ POLICY VÀ OPA

CHƯƠNG 3. PHƯƠNG PHÁP THỰC NGHIỆM

3.4. DANH MỤC 26 CA KIỂM THỬ

CHƯƠNG 4. KẾT QUẢ KIỂM THỬ

4.4. GIAO DỊCH VÀ GIỚI HẠN

4.5. TOKEN, LOG VÀ HỒI QUY

4.6. ĐỘ TRỄ THỰC NGHIỆM

CHƯƠNG 5. ĐÁNH GIÁ VÀ GIỚI HẠN

5.2. AN TOÀN VÀ ĐẠO ĐỨC

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

TÀI LIỆU THAM KHẢO

PHỤ LỤC A. MA TRẬN QUYỀN ĐẦY ĐỦ

PHỤ LỤC B. KẾT QUẢ 26 CA

PHỤ LỤC C. VÍ DỤ REQUEST, RESPONSE VÀ LOG

BOLA support ngoài ticket

Support có ticket

BOLA customer

Customer hợp lệ

Không có token

Sửa hồ sơ hợp lệ

BFLA support nâng role

Admin hợp lệ

Admin thiếu MFA

Admin tự nâng quyền

Mass assignment

Chuyển từ tài khoản khác

Gửi lặp giao dịch

Gửi song song cùng key

Cùng key khác nội dung

Chia nhỏ vượt hạn mức

Giới hạn đăng nhập

Đăng nhập dưới ngưỡng

Giới hạn page size

JWT sai audience

JWT hết hạn

Agent không được ghi

Log có ID, không lộ token

MỞ ĐẦU

API là điểm tiếp xúc giữa người dùng, ứng dụng và dữ liệu. Việc xác thực thành công chỉ xác nhận danh tính người gọi; nó không chứng minh người đó được truy cập mọi tài nguyên hoặc thực hiện mọi chức năng. Lỗi BOLA xảy ra khi API tiếp nhận mã đối tượng từ yêu cầu nhưng không kiểm tra quan hệ của người gọi với bản ghi tương ứng. BFLA xuất hiện khi chức năng quản trị thiếu ràng buộc vai trò hoặc phạm vi quyền.

Mục tiêu của đề tài là nhận diện các lỗi này, thiết kế kiểm soát token và nghiệp vụ, rồi kiểm tra hồi quy trên cùng tập tình huống. Đề tài bám sát các mục 6.2, 6.3 và 6.8 của học phần. Phạm vi thực nghiệm giới hạn ở API tự viết trên máy cục bộ, không sử dụng endpoint, tài khoản hoặc token của hệ thống thật.

Phương pháp thực hiện gồm năm bước: xác định ma trận quyền; dựng bản API có lỗi; tạo ca kiểm thử; bổ sung kiểm soát; chạy lại toàn bộ bộ test và đối chiếu kết quả trước/sau. Các sản phẩm gồm mã nguồn, ma trận quyền, request/response đã khử bí mật, kết quả máy đọc được và log từ chối có mã tương quan.

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT

1.1. Xác thực và quản lý phiên. Xác thực liên kết request với một chủ thể. Trong lab, chủ thể được thể hiện qua JWT có chữ ký HMAC. Sau khi kiểm tra chữ ký, API cần kiểm issuer, audience, thời hạn và scope. Nếu bỏ qua một trong các điều kiện này, token hợp lệ về mặt định dạng vẫn có thể được dùng sai bối cảnh.

1.2. Phân quyền chức năng và phân quyền đối tượng. Phân quyền chức năng xác định một vai trò có được gọi route quản trị hay không. Phân quyền đối tượng kiểm tra bản ghi cụ thể có thuộc phạm vi của chủ thể hay không. Hai lớp kiểm tra cần được thực hiện sau xác thực và trước khi tiết lộ dữ liệu hoặc thay đổi trạng thái.

1.3. Quyền tối thiểu. Scope trong token là một điều kiện cần, nhưng không thay thế kiểm tra role hiện tại, quyền sở hữu, ticket hỗ trợ hoặc điều kiện nghiệp vụ. Chữ ký token chỉ xác nhận nội dung không bị sửa theo khóa ký; nó không làm cho mọi tuyên bố trong token trở thành quyền truy cập vô điều kiện.

1.4. CÁC KIỂU LỖI API TRỌNG YẾU

BOLA được mô phỏng bằng yêu cầu của Alice tới tài khoản thuộc Bob và bằng yêu cầu của nhân viên hỗ trợ tới tài khoản không có ticket. BFLA được mô phỏng bằng việc nhân viên hỗ trợ gọi route đổi vai trò. Mass assignment xuất hiện khi client gửi trường role trong request sửa hồ sơ; role phải do chức năng quản trị quyết định, không thuộc dữ liệu người dùng tự sửa.

Lạm dụng tài nguyên không chỉ là gửi nhiều request. Một giao dịch có thể bị nhân đôi khi client gửi lại sau lỗi mạng; hai request cùng khóa có thể đến đồng thời; hoặc người dùng chia nhỏ giao dịch nhằm né giới hạn theo từng lệnh. Do đó, kiểm soát cần xét idempotency, khóa nguyên tử và hạn mức cộng dồn.

Tập tình huống còn kiểm tra đăng nhập lặp, page size quá lớn, token sai audience, token hết hạn và tác nhân chỉ có quyền đọc nhưng cố ghi. Các tình huống được chọn để liên kết trực tiếp từng nguy cơ với policy và bằng chứng kiểm thử.

1.5. NGUYÊN TẮC KIỂM SOÁT

Validation schema theo danh sách trường được phép ngăn client ghi những thuộc tính do máy chủ quản lý. Idempotency-Key định danh một ý định giao dịch; cùng khóa và cùng nội dung phải cho cùng kết quả, còn cùng khóa với nội dung khác phải bị từ chối. Cơ chế này cần giữ tính nguyên tử khi nhiều request đến đồng thời.

Rate limit giảm tốc độ thử đăng nhập hoặc tiêu thụ tài nguyên. Giới hạn page size chặn phản hồi quá lớn. Hạn mức chuyển tiền cần xét tổng các giao dịch đã thực hiện trong một khoảng xác định thay vì chỉ so từng khoản độc lập. Trong lab, phép cộng dồn là theo toàn bộ thời gian sống của tiến trình, vì dữ liệu không được lưu bền.

Ghi log có ngữ cảnh phải liên kết request, chủ thể, route, quyết định, policy và mã trạng thái, đồng thời tránh ghi bearer token, bí mật và dữ liệu cá nhân không cần thiết. Mã X-Request-ID trả về cho client giúp đối chiếu phản hồi với nhật ký.

CHƯƠNG 2. THIẾT KẾ LAB

2.1. Phạm vi. MiniBank-Lab là ứng dụng FastAPI với hai tài khoản acc-a và acc-b do Alice và Bob sở hữu. Hệ thống có các chủ thể customer, support, admin và agent. Các bản ghi được khởi tạo lại trong từng ca của bộ test Python, bảo đảm một ca không làm sai lệch dữ liệu đầu vào của ca tiếp theo.

2.2. Thành phần. Client gửi HTTP request mang token tới API. API kiểm tra xác thực, scope, vai trò, quan hệ sở hữu hoặc ticket, schema và điều kiện nghiệp vụ. Dữ liệu nằm trong bộ nhớ tiến trình. Middleware bổ sung X-Request-ID và ghi log quyết định. Cấu hình Compose còn mô tả OPA như dịch vụ policy nội bộ; kết quả 26 ca trong báo cáo được chạy ở chế độ Python không đặt OPA_URL.

2.3. Ranh giới tin cậy. Ranh giới thứ nhất nằm giữa client và API; thứ hai giữa token và bộ xác minh; thứ ba giữa logic phân quyền và dữ liệu tài khoản; thứ tư giữa API và log. Dữ liệu từ client luôn là đầu vào không đáng tin và không được tự quyết định owner, role hoặc điều kiện ticket.

2.4. MA TRẬN PHÂN QUYỀN

Ma trận hiện có 24 quy tắc. Mỗi dòng nêu chủ thể, phương thức, route, điều kiện, quyết định, scope và ca minh chứng. Bảng đầy đủ ở Phụ lục A; các quy tắc đại diện được tóm tắt dưới đây.

Policy	Chủ thể	Hành động	Điều kiện	Quyết định
P01	anonymous	GET /accounts/{id}	missing_token	deny
P02	customer	GET /accounts/{id}	owner_is_subject	allow
P03	customer	GET /accounts/{id}	owner_differs	deny
P04	customer	POST /transfers	source_owner_and_limit_and_key	allow
P05	customer	POST /transfers	source_not_owned	deny
P06	customer	PATCH /profile/{id}	self_and_allowed_fields	allow
P07	support	GET /support/accounts/{id}	open_ticket	allow_masked
P08	support	GET /support/accounts/{id}	no_open_ticket	deny
P09	support	POST /admin/users/{id}/role	not_admin	deny

Ma trận được lập trước khi kiểm thử để mọi ca đều có một kỳ vọng độc lập với phản hồi của ứng dụng. Đây là cơ sở đánh giá đúng/sai và giúp phát hiện chỗ thiếu policy.

2.5. MÔ HÌNH ĐE DỌA

Nhóm áp dụng STRIDE để nhận diện 13 mối đe dọa gắn với luồng dữ liệu và chức năng. T01–T03 tập trung vào rò rỉ hoặc sửa dữ liệu sai đối tượng; T04 là nâng quyền qua chức năng quản trị; T05 là sửa trường không cho phép; T06–T09 là phát lại, cạnh tranh và né giới hạn giao dịch; T10–T11 là tiêu thụ tài nguyên; T12 là sử dụng token sai bối cảnh; T13 là thiếu khả năng truy vết.

Với mỗi mối đe dọa, nhóm gắn một điểm kiểm soát và ít nhất một ca thực nghiệm. Cách liên kết này cho phép đối chiếu trực tiếp giữa phân tích nguy cơ và kết quả test, tránh liệt kê nguy cơ chỉ ở mức khái niệm. Bảng chi tiết nằm trong tài liệu THREAT_MODEL.md của dự án.

Mô hình chỉ bao phủ chức năng được cài đặt trong MiniBank-Lab. Khi thêm route, trường dữ liệu hoặc hệ thống danh tính bên ngoài, cần cập nhật ranh giới tin cậy và ma trận trước khi mở rộng bộ kiểm thử.

2.6. ĐẶC TẢ POLICY VÀ OPA

Các kiểm tra chính trong ứng dụng gồm: owner bằng subject cho route tài khoản; nhân viên hỗ trợ phải có ticket còn hiệu lực; route quản trị cần role và scope phù hợp; đổi vai trò yêu cầu MFA và không cho tự đổi; profile chỉ chấp nhận full_name và phone; chuyển khoản phải lấy nguồn thuộc người gọi.

Tệp Rego app/policy/after/minibank.rego mô tả sáu quyết định theo subject, role, MFA và thuộc tính tài nguyên do máy chủ cung cấp. Khi cấu hình OPA_URL, API gửi input tới quyết định minibank/authz/allow. Nếu OPA không trả result: true, API từ chối. Bộ Python 26 ca chạy qua ASGI không bật OPA; OPA được xác minh riêng qua Docker Compose, với quyết định true/false và phản hồi API 200/403 có correlation ID trong tests/results/opa_runtime.json.

Việc tách policy cho phép đối chiếu ma trận, mã ứng dụng và quyết định OPA. Thử nghiệm runtime đã xác minh đường gọi OPA và hai quyết định cho phép/từ chối; chưa đo độ trễ khi sidecar được bật dưới tải lặp lại.

CHƯƠNG 3. PHƯƠNG PHÁP THỰC NGHIỆM

3.1. Tập ca. Bộ Python có 26 tình huống. Mỗi tình huống tạo một thể hiện ứng dụng và dữ liệu khởi tạo riêng, sau đó gửi request bằng HTTPX qua ASGI. Cả hai chế độ trước và sau sửa được chạy với cùng đầu vào. Kỳ vọng của bản sau sửa gồm mã HTTP, trạng thái tài khoản/giao dịch và một số điều kiện log.

3.2. Chỉ số. Tỷ lệ đạt được tính bằng số ca đáp ứng điều kiện an toàn chia cho tổng số ca. Các ca hợp lệ phải tiếp tục hoạt động, do đó không đánh đồng việc từ chối mọi request với kiểm soát đúng. Độ trễ được đo qua 20 request làm nóng và 100 request lấy mẫu cho mỗi chế độ, sau đó báo cáo trung vị và p95.

3.3. Minh chứng. Script lưu JSON gồm mô tả request đã bỏ token, response, trạng thái dữ liệu, log cuối và X-Request-ID. Tệp JUnit cho phép máy đọc kết quả. Trang HTML thể hiện bảng trước/sau. Postman và Newman cung cấp demo trực quan cho BOLA nhưng mới có ba assertions mỗi collection, không thay thế bộ 26 ca Python.

3.4. DANH MỤC 26 CA KIỂM THỬ

STT	Ca kiểm thử	Trước	Sau
1	BOLA support ngoài ticket	200	403
2	Support có ticket	200	200
3	BOLA customer	200	403
4	Customer hợp lệ	200	200
5	Không có token	401	401
6	Sửa hồ sơ hợp lệ	200	200
7	BFLA support nâng role	200	403

STT	Ca kiểm thử	Trước	Sau
8	Thiếu scope admin	200	403
9	Admin hợp lệ	200	200
10	Admin thiếu MFA	200	403
11	Admin tự nâng quyền	200	403
12	Mass assignment	200	400
13	Chuyển từ tài khoản khác	200	403
14	Gửi lặp giao dịch	200	200
15	Gửi song song cùng key	400	200
16	Cùng key khác nội dung	200	409
17	Chia nhỏ vượt hạn mức	200	403
18	Giới hạn đăng nhập	401	429
19	Đăng nhập dưới ngưỡng	401	401
20	Rate limit tách tài khoản	401	401
21	Rate limit hết cửa sổ	401	401
22	Giới hạn page size	200	400
23	JWT sai audience	200	401
24	JWT hết hạn	200	401
25	Agent không được ghi	200	403
26	Log có ID, không lộ token	200	403

Mã HTTP chỉ là tóm tắt. Điều kiện đạt trong Python còn xét trạng thái dữ liệu hoặc log khi cần, đặc biệt với ca giao dịch lặp và gửi song song.

CHƯƠNG 4. KẾT QUẢ KIỂM THỬ

4.1. Phân quyền đối tượng. Alice đọc acc-b trả 200 ở bản trước và 403 ở bản sau. Nhân viên hỗ trợ đọc tài khoản ngoài ticket cũng chuyển từ 200 sang 403. Truy cập hợp lệ của Alice đối với acc-a và của nhân viên hỗ trợ đối với tài khoản có ticket vẫn trả 200. Như vậy, kiểm soát đã phân biệt được quyền theo bản ghi cụ thể.

4.2. Phân quyền chức năng. Nhân viên hỗ trợ đổi vai trò qua route admin trả 200 ở bản trước và 403 ở bản sau. Admin hợp lệ có MFA vẫn đổi được vai trò người khác. Admin thiếu MFA và admin tự đổi quyền bị chặn ở bản sau. Các ca này cho thấy scope, role, MFA và quan hệ giữa chủ thể với mục tiêu cần được xét đồng thời.

4.3. Mass assignment. Request PATCH hồ sơ mang role=admin trả 200 ở bản trước và 400 ở bản sau. Schema của bản sau chỉ cho phép full_name và phone. Ca sửa phone hợp lệ vẫn trả 200; kiểm soát không làm mất chức năng chính đáng.

4.4. GIAO DỊCH VÀ GIỚI HẠN

Chuyển khoản từ acc-b bằng token Alice trả 200 ở bản trước và 403 ở bản sau. Khi gửi lại cùng Idempotency-Key và cùng nội dung, bản sau chỉ tạo một giao dịch; bản trước tạo thêm bản ghi. Ca gửi song song cùng khóa kiểm tra tính nguyên tử của vùng ghi dữ liệu, không chỉ so sánh phản hồi HTTP.

Khi tái sử dụng cùng khóa với nội dung khác, bản sau trả 409 Conflict. Ca chia nhỏ bốn giao dịch 20 đơn vị kiểm tra tổng lũy kế: ba lệnh đầu trong hạn mức, lệnh thứ tư bị từ chối vì vượt ngưỡng cộng dồn 70. Đây là kiểm tra nghiệp vụ độc lập với giới hạn giá trị của từng request.

Hệ thống từ chối lần đăng nhập thứ tư trong cửa sổ 60 giây theo địa chỉ kết nối và tài khoản; các tài khoản khác được đếm riêng và yêu cầu được thử lại khi cửa sổ kết thúc. Giới hạn limit=1000000 khi liệt kê giao dịch cũng bị chặn. Trạng thái rate limit còn ở bộ nhớ một tiến trình; nhiều instance cần kho đếm dùng chung.

4.5. TOKEN, LOG VÀ HỒI QUY

JWT sai audience và JWT hết hạn được bản sau từ chối với HTTP 401. Token của agent chỉ có quyền đọc không thể tạo giao dịch. Những kết quả này cho thấy chữ ký hợp lệ không thay thế kiểm tra ngữ cảnh và phạm vi sử dụng token.

Middleware trả X-Request-ID và ghi subject, route, policy, trạng thái, quyết định cùng thời lượng. Ca log kiểm tra có thể liên kết mã phản hồi với một bản ghi và không thấy bearer token trong log. Log mẫu không chứa dữ liệu ngân hàng thật do toàn bộ môi trường dùng dữ liệu tổng hợp.

Lần chạy dùng trong báo cáo có 26/26 ca đáp ứng điều kiện của bản sau sửa. Chỉ số này thể hiện tỷ lệ đạt của tập ca đã viết, không phải mức bao phủ toàn bộ không gian lỗi API. Không có ca hợp lệ nào trong tập kiểm thử bị chặn sai theo điều kiện hiện tại.

4.6. ĐỘ TRỄ THỰC NGHIỆM

Trung vị trước sửa là 1,491 ms, sau sửa là 1,470 ms. p95 trước sửa là 2,781 ms, sau sửa là 2,970 ms. Chênh lệch p95 của lần chạy là 0,189 ms. Đây là số đo ASGI cùng tiến trình, không phải phép đo overhead OPA trong Docker.

Phép đo được thực hiện bằng HTTPX ASGITransport trong cùng tiến trình với 20 request làm nóng và 100 request đo ở mỗi chế độ. Nó loại bỏ nhiều chi phí mạng và container, đồng thời chịu ảnh hưởng của hệ điều hành, lịch chạy và tải máy. Vì vậy, không thể suy ra overhead trong production từ một lần chạy.

Để đánh giá hiệu năng triển khai, cần lặp lại nhiều lần trên phần cứng cố định, chạy qua HTTP thật, xác định phân phối độ trễ, số request đồng thời và cấu hình OPA. Báo cáo hiện chỉ dùng số đo để thỏa yêu cầu thực nghiệm trong phạm vi lab.

CHƯƠNG 5. ĐÁNH GIÁ VÀ GIỚI HẠN

Điểm mạnh của lab là mối liên hệ trực tiếp giữa ma trận quyền, policy, ca kiểm thử và bằng chứng trước/sau. Các tình huống hợp lệ được giữ trong bộ test để phát hiện chặn sai. Trạng thái dữ liệu được kiểm tra trong các ca giao dịch, nhờ đó phản hồi HTTP đơn lẻ không thể che việc ghi dữ liệu hai lần.

Giới hạn chính là dữ liệu trong bộ nhớ: khởi động lại làm mất giao dịch, ticket và bộ đếm. JWT dùng khóa HS256 tĩnh chỉ phục vụ lab; không mô phỏng cấp phát, thu hồi và luân chuyển khóa của hệ thống thật. Rate limit chưa phân tán; log chưa đẩy tới kho tập trung bất biến; thời gian “hằng ngày” trong mã là tổng kể từ lúc tiến trình chạy.

Docker Compose và OPA sidecar đã chạy trên máy lab. tests/verify_opa.py xác nhận quyết định trực tiếp true/false và phản hồi API 200/403; minh chứng đã khử token nằm trong tests/results/opa_runtime.json. Bộ 26 ca Python chạy riêng với policy trong ứng dụng. Postman/Newman có ba assertions BOLA trên mỗi phiên bản, chưa bao phủ toàn bộ bộ Python.

5.2. AN TOÀN VÀ ĐẠO ĐỨC

Mọi kiểm thử chỉ thực hiện trên localhost hoặc mạng cô lập của Compose. Tên người dùng, tài khoản, số dư, token và giao dịch đều là dữ liệu giả. Không gửi request tới dịch vụ bên ngoài, không dùng tài khoản hoặc endpoint thật và không quét hệ thống không thuộc phạm vi lab.

Request/response dùng làm minh chứng được khử token. Khi chụp màn hình Postman hoặc terminal, cần tránh để lộ bearer token hoặc khóa lab; dù là dữ liệu giả, thói quen khử bí mật giúp người xem phân biệt cách trình bày minh chứng đúng với việc phát tán thông tin xác thực.

Khi bảo vệ, cần nêu rõ các lỗ hổng ở chế độ before được tạo có chủ đích để quan sát hiệu quả kiểm soát. Không triển khai chế độ này trên mạng công cộng hoặc dùng như ứng dụng tài chính thực tế.

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

Nghiên cứu đã xây dựng API lab, ma trận 24 quy tắc và bộ 26 ca kiểm thử nhằm đánh giá phân quyền đối tượng, chức năng và giới hạn lạm dụng API. Sau khi bổ sung kiểm soát, tất cả 26 ca trong bộ Python đáp ứng điều kiện kiểm tra. Kết quả cho thấy cần kết hợp xác thực token với quyết định theo đối tượng, schema, idempotency, rate limit và ghi log có ngữ cảnh.

Hướng phát triển gồm đo overhead của quyết định OPA từ xa dưới tải lặp lại; mở rộng Postman/Newman tới các ca có trạng thái bằng cơ chế reset lab an toàn; thay trạng thái rate limit trong tiến trình bằng kho dùng chung; bổ sung quy trình cấp và thu hồi token qua nhà cung cấp danh tính. Mỗi mở rộng cần cập nhật ma trận quyền và bộ hồi quy trước khi công bố kết quả mới.

TÀI LIỆU THAM KHẢO

[1] OWASP, OWASP API Security Top 10, https://owasp.org/API-Security/.

[2] IETF, RFC 7519: JSON Web Token (JWT), https://www.rfc-editor.org/rfc/rfc7519.

[3] Open Policy Agent, Integrating OPA, https://www.openpolicyagent.org/docs/integration.

[4] Postman, Test your API using the Collection Runner, https://learning.postman.com/latest-v-12/docs/tests-and-scripts/running-collections/intro-to-collection-runs/.

[5] Postman Labs, Newman documentation, https://github.com/postmanlabs/newman.

[6] Tài liệu học phần, Chương 6: An toàn thông tin trong kiến trúc hệ thống hiện đại (tệp do giảng viên cung cấp).

[7] Quy định về hình thức trình bày báo cáo bài tập lớn (tệp do giảng viên cung cấp).

PHỤ LỤC A. MA TRẬN QUYỀN ĐẦY ĐỦ

Mã	Chủ thể	Phương thức / route	Điều kiện	QĐ
P01	anonymous	GET /accounts/{id}	missing_token	deny
P02	customer	GET /accounts/{id}	owner_is_subject	allow
P03	customer	GET /accounts/{id}	owner_differs	deny
P04	customer	POST /transfers	source_owner_and_limit_and_key	allow
P05	customer	POST /transfers	source_not_owned	deny
P06	customer	PATCH /profile/{id}	self_and_allowed_fields	allow
P07	support	GET /support/accounts/{id}	open_ticket	allow_masked
P08	support	GET /support/accounts/{id}	no_open_ticket	deny
P09	support	POST /admin/users/{id}/role	not_admin	deny
P10	admin	POST /admin/users/{id}/role	current_admin_and_mfa_and_not_self	allow
P11	admin	POST /admin/users/{id}/role	no_mfa	deny
P12	customer	PATCH /profile/{id}	forbidden_field	deny
P13	customer	POST /transfers	same_key_same_body	one_transaction
P14	customer	POST /transfers	same_key_different_body	deny_conflict
P15	customer	POST /transfers	cumulative_amount_exceeds_70	deny
P16	anonymous	POST /auth/login	more_than_3_attempts	rate_limit
P17	customer	GET /transfers	limit_exceeds_100	deny
P18	customer	GET /accounts/{id}	wrong_audience_or_expired	deny
P19	admin	POST /admin/users/{self}/role	self_change	deny
P20	agent	POST /transfers	read_only_scope	deny
P21	anonymous	POST /auth/login	at_or_below_3_attempts	allow_attempt
P22	support	GET /admin/users	missing_admin_scope	deny
P23	anonymous	POST /auth/login	different_account_same_source_independent_window	allow_attempt
P24	anonymous	POST /auth/login	60_second_window_elapsed	allow_attempt

PHỤ LỤC B. KẾT QUẢ 26 CA

STT	Ca	Trước	Sau	Đạt
1	BOLA support ngoài ticket	200	403	Có
2	Support có ticket	200	200	Có
3	BOLA customer	200	403	Có
4	Customer hợp lệ	200	200	Có
5	Không có token	401	401	Có
6	Sửa hồ sơ hợp lệ	200	200	Có

STT	Ca	Trước	Sau	Đạt
7	BFLA support nâng role	200	403	Có
8	Thiếu scope admin	200	403	Có
9	Admin hợp lệ	200	200	Có
10	Admin thiếu MFA	200	403	Có
11	Admin tự nâng quyền	200	403	Có
12	Mass assignment	200	400	Có
13	Chuyển từ tài khoản khác	200	403	Có
14	Gửi lặp giao dịch	200	200	Có
15	Gửi song song cùng key	400	200	Có
16	Cùng key khác nội dung	200	409	Có
17	Chia nhỏ vượt hạn mức	200	403	Có
18	Giới hạn đăng nhập	401	429	Có
19	Đăng nhập dưới ngưỡng	401	401	Có
20	Rate limit tách tài khoản	401	401	Có
21	Rate limit hết cửa sổ	401	401	Có
22	Giới hạn page size	200	400	Có
23	JWT sai audience	200	401	Có
24	JWT hết hạn	200	401	Có
25	Agent không được ghi	200	403	Có
26	Log có ID, không lộ token	200	403	Có

PHỤ LỤC C. VÍ DỤ REQUEST, RESPONSE VÀ LOG

BOLA support ngoài ticket

Request đã khử bí mật: GET /support/accounts/acc-b; actor=sam; scope=support:read

HTTP trước/sau: 200 / 403. Response sau: {"detail": "ticket_required"}

X-Request-ID: 101695ec-39ec-4926-9a19-28e8db4b6d95; log: {"request_id": "101695ec-39ec-4926-9a19-28e8db4b6d95", "subject": "sam", "method": "GET", "route": "/support/accounts/{account_id}", "decision": "deny", "policy_id": "P08/P14", "status": 403, "duration_ms": 2.766}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Support có ticket

Request đã khử bí mật: GET /support/accounts/acc-a; actor=sam; scope=support:read

HTTP trước/sau: 200 / 200. Response sau: {"id": "acc-a", "owner": "alice", "balance": "MASKED"}

X-Request-ID: 152091f6-318a-4709-b6a8-610db7216058; log: {"request_id": "152091f6-318a-4709-b6a8-610db7216058", "subject": "sam", "method": "GET", "route": "/support/accounts/{account_id}", "decision": "allow", "policy_id": "P08/P14", "status": 200, "duration_ms": 1.146}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

BOLA customer

Request đã khử bí mật: GET /accounts/acc-b; actor=alice

HTTP trước/sau: 200 / 403. Response sau: {"detail": "forbidden"}

X-Request-ID: 687188e7-a496-4f8e-8eca-e4f57d8e2453; log: {"request_id": "687188e7-a496-4f8e-8eca-e4f57d8e2453", "subject": "alice", "method": "GET", "route": "/accounts/{account_id}", "decision": "deny", "policy_id": "P02", "status": 403, "duration_ms": 1.507}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Customer hợp lệ

Request đã khử bí mật: GET /accounts/acc-a; actor=alice

HTTP trước/sau: 200 / 200. Response sau: {"id": "acc-a", "balance": 100, "owner": "alice"}

X-Request-ID: ac20adb1-68e3-4bb5-b973-31e996852b15; log: {"request_id": "ac20adb1-68e3-4bb5-b973-31e996852b15", "subject": "alice", "method": "GET", "route": "/accounts/{account_id}", "decision": "allow", "policy_id": "P02", "status": 200, "duration_ms": 2.204}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Không có token

Request đã khử bí mật: GET /accounts/acc-a; Authorization absent

HTTP trước/sau: 401 / 401. Response sau: {"detail": "missing_token"}

X-Request-ID: aa8fda9c-e591-4d57-bfb1-b7a6fbf2b31a; log: {"request_id": "aa8fda9c-e591-4d57-bfb1-b7a6fbf2b31a", "subject": "anonymous", "method": "GET", "route": "/accounts/{account_id}", "decision": "deny", "policy_id": "P-DEFAULT", "status": 401, "duration_ms": 1.018}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Sửa hồ sơ hợp lệ

Request đã khử bí mật: PATCH /profile/alice; body={phone:000-009}

HTTP trước/sau: 200 / 200. Response sau: {"full_name": "Alice Lab", "phone": "000-009", "role": "customer"}

X-Request-ID: 21d24a53-2c81-479d-abcc-10269736ca1d; log: {"request_id": "21d24a53-2c81-479d-abcc-10269736ca1d", "subject": "alice", "method": "PATCH", "route": "/profile/{user_id}", "decision": "allow", "policy_id": "P06", "status": 200, "duration_ms": 2.564}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

BFLA support nâng role

Request đã khử bí mật: POST /admin/users/sam/role; actor=sam; body={role:admin}

HTTP trước/sau: 200 / 403. Response sau: {"detail": "missing_scope"}

X-Request-ID: 33e88456-b457-4c4e-8871-538e44da9d94; log: {"request_id": "33e88456-b457-4c4e-8871-538e44da9d94", "subject": "sam", "method": "POST", "route": "/admin/users/{user_id}/role", "decision": "deny", "policy_id": "P-DEFAULT", "status": 403, "duration_ms": 1.691}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Admin hợp lệ

Request đã khử bí mật: POST /admin/users/bob/role; actor=admin; MFA=true

HTTP trước/sau: 200 / 200. Response sau: {"user_id": "bob", "role": "support"}

X-Request-ID: b2d71084-4e98-411a-b420-4e018c2bffd1; log: {"request_id": "b2d71084-4e98-411a-b420-4e018c2bffd1", "subject": "admin", "method": "POST", "route": "/admin/users/{user_id}/role", "decision": "allow", "policy_id": "P10/P15/P17", "status": 200, "duration_ms": 3.36}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Admin thiếu MFA

Request đã khử bí mật: POST /admin/users/bob/role; actor=admin; MFA=false

HTTP trước/sau: 200 / 403. Response sau: {"detail": "forbidden"}

X-Request-ID: e4be425a-ad15-44b1-a76e-9027f391ff03; log: {"request_id": "e4be425a-ad15-44b1-a76e-9027f391ff03", "subject": "admin", "method": "POST", "route": "/admin/users/{user_id}/role", "decision": "deny", "policy_id": "P10/P15/P17", "status": 403, "duration_ms": 1.033}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Admin tự nâng quyền

Request đã khử bí mật: POST /admin/users/admin/role; actor=admin; MFA=true

HTTP trước/sau: 200 / 403. Response sau: {"detail": "forbidden"}

X-Request-ID: 062194a8-5b2e-4dda-9651-95c79bca38c9; log: {"request_id": "062194a8-5b2e-4dda-9651-95c79bca38c9", "subject": "admin", "method": "POST", "route": "/admin/users/{user_id}/role", "decision": "deny", "policy_id": "P10/P15/P17", "status": 403, "duration_ms": 1.656}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Mass assignment

Request đã khử bí mật: PATCH /profile/alice; body={role:admin}

HTTP trước/sau: 200 / 400. Response sau: {"detail": "invalid_fields"}

X-Request-ID: 811c16a2-4fe8-4dec-a4dd-352d25d09235; log: {"request_id": "811c16a2-4fe8-4dec-a4dd-352d25d09235", "subject": "alice", "method": "PATCH", "route": "/profile/{user_id}", "decision": "deny", "policy_id": "P06", "status": 400, "duration_ms": 1.769}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Chuyển từ tài khoản khác

Request đã khử bí mật: POST /transfers; actor=alice; source=acc-b; amount=10

HTTP trước/sau: 200 / 403. Response sau: {"detail": "source_not_owned"}

X-Request-ID: 46b024df-01cb-46d0-9ddf-d720d3044948; log: {"request_id": "46b024df-01cb-46d0-9ddf-d720d3044948", "subject": "alice", "method": "POST", "route": "/transfers", "decision": "deny", "policy_id": "P04/P05", "status": 403, "duration_ms": 2.111}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Gửi lặp giao dịch

Request đã khử bí mật: POST /transfers x5; same Idempotency-Key; amount=10

HTTP trước/sau: 200 / 200. Response sau: {"id": "tr-1", "source": "acc-a", "destination": "acc-b", "amount": 10}

X-Request-ID: aae21db3-6a27-4872-8043-e67991ac1378; log: {"request_id": "aae21db3-6a27-4872-8043-e67991ac1378", "subject": "alice", "method": "POST", "route": "/transfers", "decision": "allow", "policy_id": "P04/P05", "status": 200, "duration_ms": 2.094}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 90, "acc-b": 110}, "transfer_count": 1, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Gửi song song cùng key

Request đã khử bí mật: POST /transfers x20 concurrent; same Idempotency-Key; amount=10

HTTP trước/sau: 400 / 200. Response sau: {"id": "tr-1", "source": "acc-a", "destination": "acc-b", "amount": 10}

X-Request-ID: 8542214b-f9d4-4f04-920f-56a317e14646; log: {"request_id": "8542214b-f9d4-4f04-920f-56a317e14646", "subject": "alice", "method": "POST", "route": "/transfers", "decision": "allow", "policy_id": "P04/P05", "status": 200, "duration_ms": 19.678}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 90, "acc-b": 110}, "transfer_count": 1, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Cùng key khác nội dung

Request đã khử bí mật: POST /transfers x2; same key; amount=10 then 20

HTTP trước/sau: 200 / 409. Response sau: {"detail": "key_reused_with_different_body"}

X-Request-ID: 4b188007-c72b-49fa-9d39-017fb19abc00; log: {"request_id": "4b188007-c72b-49fa-9d39-017fb19abc00", "subject": "alice", "method": "POST", "route": "/transfers", "decision": "deny", "policy_id": "P04/P05", "status": 409, "duration_ms": 1.673}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 90, "acc-b": 110}, "transfer_count": 1, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Chia nhỏ vượt hạn mức

Request đã khử bí mật: POST /transfers x4; distinct keys; amount=20 each

HTTP trước/sau: 200 / 403. Response sau: {"detail": "daily_limit"}

X-Request-ID: 26c03b75-461e-4f8e-b427-6ba7f53da5ac; log: {"request_id": "26c03b75-461e-4f8e-b427-6ba7f53da5ac", "subject": "alice", "method": "POST", "route": "/transfers", "decision": "deny", "policy_id": "P04/P05", "status": 403, "duration_ms": 2.585}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 40, "acc-b": 160}, "transfer_count": 3, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Giới hạn đăng nhập

Request đã khử bí mật: POST /auth/login x5; synthetic invalid credentials

HTTP trước/sau: 401 / 429. Response sau: {"detail": "rate_limited"}

X-Request-ID: bbbf6f9f-c48d-47c9-878f-2a652c53f4f8; log: {"request_id": "bbbf6f9f-c48d-47c9-878f-2a652c53f4f8", "subject": "anonymous", "method": "POST", "route": "/auth/login", "decision": "deny", "policy_id": "P-RATE", "status": 429, "duration_ms": 0.584}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Đăng nhập dưới ngưỡng

Request đã khử bí mật: POST /auth/login x3; synthetic invalid credentials

HTTP trước/sau: 401 / 401. Response sau: {"detail": "invalid_credentials"}

X-Request-ID: ebc17ee6-8ce6-4512-868b-649db2a1f7ea; log: {"request_id": "ebc17ee6-8ce6-4512-868b-649db2a1f7ea", "subject": "anonymous", "method": "POST", "route": "/auth/login", "decision": "deny", "policy_id": "P-RATE", "status": 401, "duration_ms": 0.669}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Giới hạn page size

Request đã khử bí mật: GET /transfers?limit=1000000

HTTP trước/sau: 200 / 400. Response sau: {"detail": "invalid_limit"}

X-Request-ID: 0e22dfd0-d54e-4772-8d1d-03e9bcc2d7f4; log: {"request_id": "0e22dfd0-d54e-4772-8d1d-03e9bcc2d7f4", "subject": "alice", "method": "GET", "route": "/transfers", "decision": "deny", "policy_id": "P-LIMIT", "status": 400, "duration_ms": 1.328}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

JWT sai audience

Request đã khử bí mật: GET /accounts/acc-a; signed lab JWT aud=other-service

HTTP trước/sau: 200 / 401. Response sau: {"detail": "invalid_token"}

X-Request-ID: a2adbcd7-8596-4ba6-a8d9-7ac83b58090d; log: {"request_id": "a2adbcd7-8596-4ba6-a8d9-7ac83b58090d", "subject": "anonymous", "method": "GET", "route": "/accounts/{account_id}", "decision": "deny", "policy_id": "P-DEFAULT", "status": 401, "duration_ms": 1.088}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

JWT hết hạn

Request đã khử bí mật: GET /accounts/acc-a; signed lab JWT exp in past

HTTP trước/sau: 200 / 401. Response sau: {"detail": "invalid_token"}

X-Request-ID: f042c70e-1eca-4e1b-b2d5-cf40671aceb3; log: {"request_id": "f042c70e-1eca-4e1b-b2d5-cf40671aceb3", "subject": "anonymous", "method": "GET", "route": "/accounts/{account_id}", "decision": "deny", "policy_id": "P-DEFAULT", "status": 401, "duration_ms": 2.233}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Agent không được ghi

Request đã khử bí mật: POST /transfers; actor=agent; read-only scope

HTTP trước/sau: 200 / 403. Response sau: {"detail": "missing_scope"}

X-Request-ID: 73d0cfbb-d045-43e1-bfcb-8f0cca3cc0f8; log: {"request_id": "73d0cfbb-d045-43e1-bfcb-8f0cca3cc0f8", "subject": "agent", "method": "POST", "route": "/transfers", "decision": "deny", "policy_id": "P-DEFAULT", "status": 403, "duration_ms": 4.932}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.

Log có ID, không lộ token

Request đã khử bí mật: GET /accounts/acc-b; actor=alice; inspect X-Request-ID and log

HTTP trước/sau: 200 / 403. Response sau: {"detail": "forbidden"}

X-Request-ID: 235c05e4-be78-4c6c-b230-37dd821f8978; log: {"request_id": "235c05e4-be78-4c6c-b230-37dd821f8978", "subject": "alice", "method": "GET", "route": "/accounts/{account_id}", "decision": "deny", "policy_id": "P02", "status": 403, "duration_ms": 1.76}

Trạng thái dữ liệu sau ca: {"balances": {"acc-a": 100, "acc-b": 100}, "transfer_count": 0, "sam_role": "support"}. Điều kiện kiểm tra của bản sau: đạt.